

מחון תשובות — בדוק את עצמך

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 מחוון תשובות — שאלות "בדוק את עצמך"

מחווון תשובות — שאלות “בדוק את עצמך”

מדריך למרצה: כל שאלות ה-“בדוק את עצמך” מכל מודולי הקורס, עם התשובה הנכונה והסבר של שורה. השאלות מופיעות בסוף כל הדגמה מעשית. אפשר להשתמש בזה כמבחן קצר בסוף שיעור, או כדף עזר לבדיקה עצמית.

סה"כ 55 שאלות ב-16 מודולים.

מודול 1 — מבוא, המעבדה ומתודולוגיה

1. בהדגמה, מהי החולשה (Vulnerability)?

- (א) שהתוכנית כתובה בפיתון
- (ב) שהסיסמה נשמרה גלויה בתוך קוד המקור
- (ג) ש-strings היא פקודה מסוכנת

✓ תשובה: ב — אחסון סוד (סיסמה) בטקסט גלוי בתוך הקוד הוא חולשה קלאסית (Hardcoded Credentials). הניצול היה לקרוא אותו; המטען היה הרגל.

2. לפי המתודולוגיה, מה עושים מיד לפני “השגת גישה” (Gaining Access)?

- (א) טשטוש עקבות
- (ב) סריקה ומיפוי (Scanning & Enumeration)
- (ג) כתיבת הדוח

✓ תשובה: ב — הסדר קבוע: Recon → Scanning → Gaining Access. אי אפשר לתקוף חולשה לפני שסרקת וגילית אותה.

3. באיזה מצב רשת ה-VM מבודד לגמרי מהרשת הביתית שלך (בלי אינטרנט)?

- Bridged (א)
- NAT (ב)
- Host-Only (ג)

✓ תשובה: ג — Host-Only יוצר רשת סגורה בין ה-VMs והמארח בלבד. Bridged דווקא חושף את

4. איפה נמצאות רשימות המילים (Wordlists) לתקיפת סיסמאות ב-Kali?

- (א) `/home/kali/`
- (ב) `/usr/share/wordlists/`
- (ג) `/etc/passwords/`

✓ תשובה: ב — `/usr/share/wordlists/` מכילה את `rockyou.txt` ועוד. זו נקודת התחלה לכל מתקפת סיסמאות.

מודול 2 — יסודות Linux (Linux Fundamentals)

1. איזו פקודה תראה קבצים מוסתרים (שמתחילים ב-`.`)?

- (א) `ls`
- (ב) `ls -la`
- (ג) `cd ..`

✓ תשובה: ב — הדגל `-a` (all) מציג גם קבצים מוסתרים; `-l` נותן פירוט מלא. `ls` לבדו מדלג עליהם.

2. מה עושה `grep "password" app.log`?

- (א) מוחק את השורות עם `password`
- (ב) מדפיס רק את השורות שמכילות `password`
- (ג) מצפין את הקובץ

✓ תשובה: ב — <תבנית> <קובץ> `grep` מדפיס את השורות התואמות בלבד. אין לו שום השפעה על הקובץ עצמו.

3. מה מיוחד בקובץ עם ביט SUID?

- (א) הוא מוסתר מ-`ls`
- (ב) הוא רץ בהרשאות הבעלים שלו, לא של מי שמריץ
- (ג) אי אפשר למחוק אותו

✓ תשובה: ב — קובץ SUID בבעלות root רץ כ-root גם כשמשמש רגיל מפעיל אותו. אם הוא פגיע — זו דרך קלאסית להפוך ל-root.

4. מה עושה הצינור | בפקודה `base64 -d | grep flag file` ?

- (א) מריץ שתי פקודות נפרדות בלי קשר
- (ב) מעביר את הפלט של `grep` כקלט ל- `base64 -d`
- (ג) שומר את הפלט לקובץ

✓ תשובה: ב — הצינור (Pipe) מעביר את הפלט של הפקודה השמאלית כקלט לפקודה הימנית. לשמירה לקובץ משתמשים ב- `>`.

מודול 3 — יסודות רשתות (Networking Fundamentals)

1. מה מייצגת כל שורה בפלט של `tracert` ?

- (א) פורט פתוח על היעד
- (ב) ראوتر (תחנה) בדרך ליעד
- (ג) חבילה שאבדה

✓ תשובה: ב — כל שורה היא צומת/ראوتر שהחבילה עברה דרכו במסע ליעד.

2. השורה `GET / HTTP/1.1` > שראית ב- `curl -v` שייכת לאיזו שכבה?

- (א) שכבה 3 (Network)
- (ב) שכבה 4 (Transport)
- (ג) שכבה 7 (Application)

✓ תשובה: ג — HTTP הוא פרוטוקול אפליקציה, שכבה 7.

3. איזו פקודה מציגה את שכבה 4 (פורטים וחיבורים)?

- (א) `ip a`
- (ב) `ss -tunp`
- (ג) `curl`

✓ תשובה: ב — ss מציג חיבורים ופורטים (שכבת התעבורה). ip a = שכבה 2-3, curl = שכבה 7.

4. מהו הדגל הראשון ([S] Flags) שראית ב- tcpdump ?

- ACK (א)
- SYN (ב)
- FIN (ג)

✓ תשובה: ב — SYN = [S], הצעד הראשון בלחיצת היד (הלקוח מבקש להתחבר).

5. הכתובת 192.168.56.10 היא —

- ציבורית (א)
- פרטית (ב)
- Loopback (ג)

✓ תשובה: ב — 192.168.x.x הוא טווח פרטי. (Loopback = 127.0.0.1).

6. מה ARP ממפה?

- שם דומיין → IP (א)
- MAC → IP (ב)
- פורט → שירות (ג)

✓ תשובה: ב — ARP מתרגם כתובת IP לכתובת MAC ברשת המקומית. (שם → IP זה DNS).

7. אחרי שעצרת את השרת (Ctrl+C), למה ss כבר לא מצא את פורט 5000?

- הפורט תמיד סגור (א)
- השירות שפתח אותו הפסיק לרוץ (ב)
- nmap מחק אותו (ג)

✓ תשובה: ב — פורט פתוח רק כל עוד השירות שמאזין עליו רץ. עצרת את השירות → הדלת נסגרה.

8. כמה מארחים שמישים יש בתת-רשת 24 / ?

- 256 (א)

- (ב) 254

- (ג) 512

✓ תשובה: ב — 256 כתובות, פחות כתובות הרשת וכתובת ה-254 Broadcast.

9. הפקודה `ping` משתמשת באיזה פרוטוקול?

- (א) TCP

- (ב) UDP

- (ג) ICMP

✓ תשובה: ג — `ping` שולח `ICMP echo request` ומקבל `echo reply`.

10. מה עושה `Follow → TCP Stream` ב-Wireshark?

- (א) סוגר את החיבור

- (ב) מציג את כל השיחה בין שני הצדדים בתצוגה אחת

- (ג) סורק פורטים

✓ תשובה: ב — הוא מרכז את כל החבילות של אותו חיבור לתצוגה קריאה אחת.

מודול 4 — סקריפטינג: Bash ו-Python (Scripting for Hackers)

1. קיבלת `Permission denied` על סקריפט חדש. מה חסר?

- (א) שכחת את ה-Shebang

- (ב) לא נתת הרשאת הרצה (`chmod +x`)

- (ג) הקובץ ריק

✓ תשובה: ב — קובץ טקסט חדש אינו ניתן-הרצה כברירת מחדל. `chmod +x` מוסיף את הרשאת ה-`execute`.

2. מה תפקיד ה-`&` בסוף שורת ה-`ping` בלולאה?

- (א) מריץ כל `ping` ברקע, כך שכולם רצים במקביל (מהיר)

- (ב) מפנה את הפלט לקובץ

- (ג) עוצר את הלולאה

✓ תשובה: א — ה- & שולח כל פקודה לרקע, כך שכל 254 ה-pings רצים במקביל; wait ממתין שכולם יסתיימו. בלי זה הסריקה הייתה איטית פי מאה.

3. בסורק, מתי הפורט נחשב פתוח?

- (א) כש- connect_ex מחזיר מספר כלשהו
- (ב) כש- connect_ex מחזיר 0
- (ג) כשמופיעה שגיאה

✓ תשובה: ב — connect_ex מחזיר 0 כשלחיצת היד הצליחה (הפורט מקשיב). כל ערך אחר = סגור/חסום.

4. מה עשה את השרת פגיע ל-Brute Force?

- (א) שהוא כתוב בפייתון
- (ב) PIN קצר (4 ספרות) בלי הגבלת מספר נסיונות
- (ג) שהוא רץ על פורט 9999

✓ תשובה: ב — מרחב קטן (10,000) + נסיונות בלתי מוגבלים = פריצה ודאית. הגנה: סיסמאות ארוכות ו-Rate Limiting / נעילת חשבון.

מודול 5 — איסוף מידע (Reconnaissance)

1. איזו פעולה היא פסיבית?

- (א) הרצת nmap על שרת היעד
- (ב) whois על הדומיין (שאילתה למאגר רישום ציבורי)
- (ג) ping ליעד

✓ תשובה: ב — whois שואל מאגר ציבורי, בלי לגעת ביעד. nmap ו-ping הם מגע ישיר = אקטיבי.

2. למה Server: Apache/2.4.49 בכותרת מסוכן לארגון?

- (א) זה חושף את הגרסה המדויקת, ותוקף יכול לחפש חולשה ידועה לאותה גרסה
- (ב) זה מאט את האתר
- (ג) זה חוסם את גוגל

✓ תשובה: א — גרסה מדויקת מאפשרת לתוקף לחפש Exploit מתאים בדיוק. מומלץ להסתיר/לזייף את הכותרת (ServerTokens Prod).

3. מה הטעות ב"הסתרת" נתיב רק דרך `robots.txt` ?

- (א) `robots.txt` מאט את השרת
- (ב) הקובץ ציבורי וקריא לכולם — הוא בעצם מפרסם את הנתיבים שרצית להסתיר
- (ג) גוגל חוסם את האתר

✓ תשובה: ב — `robots.txt` רק מבקש ממנועי חיפוש לא לאנדקס; הוא אינו הגנה. תוקף קורא אותו ראשון כדי לגלות נתיבים "מוסתרים".

מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

1. מה עושה `sn -nmap` ?

- (א) סורק את כל 65,535 הפורטים
- (ב) גילוי מארחים חיים בלבד, בלי סריקת פורטים
- (ג) מזהה מערכת הפעלה

✓ תשובה: ב — `sn -nmap (no port scan)` רק בודק מי חי ברשת. זהו הצעד הראשון לפני שסורקים פורטים.

2. מהו "Banner Grabbing" ?

- (א) חסימת פורט
- (ב) התחברות לשירות וקריאת המידע (כולל גרסה) שהוא מציג
- (ג) הצפנת התעבורה

✓ תשובה: ב — מתחברים לפורט וקוראים את ה-Banner שהשירות שולח; הוא מסגיר לרוב את סוג השירות וגרסתו המדויקת.

3. מה עושה `gobuster dir` ?

- (א) מנחש שמות של נתיבים/קבצים באתר לפי רשימת מילים, ומדווח אילו קיימים
- (ב) מפיל את השרת
- (ג) מפענח סיסמאות

✓ תשובה: א — הוא שולח בקשות לנתיבים מרשימה (wordlist) ומזהה לפי קוד התגובה אילו קיימים — מגלה דפי ניהול/גיבוי מוסתרים.

4. מה מספק `searchsploit apache 1.3.20` ?

- (א) מפעיל אוטומטית Exploit על היעד
- (ב) מחפש במאגר Exploit-DB המקומי חולשות ידועות לגרסה הזו
- (ג) מעדכן את Apache

✓ תשובה: ב — `searchsploit` הוא חיפוש מקומי במאגר Exploit-DB. הוא רק מוצא/מציג — ההרצה בפועל היא שלב הניצול (מודול 7).

מודול 7 — ניצול והשגת גישה (Exploitation)

1. ב-Reverse Shell, מי יוזם את החיבור?

- (א) התוקף מתחבר לקורבן
- (ב) הקורבן מתחבר לתוקף (שמאזין)
- (ג) אף אחד — זה אוטומטי

✓ תשובה: ב — ב-Reverse Shell הקורבן "מתקשר הביתה" אל ה-Listener של התוקף. לכן זה עוקף חומות אש שחוסמות חיבורים נכנסים.

2. מה גרם לחולשת ה-Command Injection?

- (א) שהשרת כתוב בפייתון
- (ב) שקלט המשתמש שורשר ישירות לפקודת `shell (shell=True)` בלי סינון
- (ג) שהפורט הוא 8080

✓ תשובה: ב — שרשור קלט לא-מסונן לפקודת מערכת מאפשר לתוקף "לשבור" את הפקודה ולהריץ משלו. ההגנה: הפרדת קוד מנתונים (ארגומנטים במקום מחרוזת, ולידציה).

מודול 8 — מתקפות סיסמאות (Password Attacks)

1. Hash שמתחיל ב-\$6\$ הוא —

- (א) MD5

- (ב sha512crypt (סיסמת Linux מ- /etc/shadow)
- NTLM (ג)

✓ תשובה: ב — התחילית \$6\$ מציינת sha512crypt, הפורמט של סיסמאות Linux ב- /etc/shadow (\$1\$ =bcrypt= \$2b\$,MD5crypt).

2. מה תפקיד המחרוזת Invalid credentials בפקודת Hydra?

- (א) הסיסמה לפריצה
- (ב) "סימן הכישלון" — כל עוד היא בתשובה, ההתחברות נכשלה; היעדרה = הצלחה
- (ג) שם המשתמש

✓ תשובה: ב — ב- http-post-form, המחרוזת האחרונה היא סימן הכישלון. Hydra מזהה הצלחה כשהתשובה לא מכילה אותה.

3. למה מתקפה לא-מקוונת (John על Hash) מהירה ושקטה יותר ממקוונת (Hydra)?

- (א) כי היא לא שולחת בקשות ליעד — הסדיקה מתבצעת מקומית על המחשב שלך
- (ב) כי John חזק מ-Hydra
- (ג) כי Hash-ים תמיד קצרים

✓ תשובה: א — offline סודקים עותק מקומי של ה-Hash, בלי לגעת ביעד: אין רעש, אין נעילת חשבון, ואפשר מיליוני נסיונות בשנייה.

מודול 9 — אבטחת אפליקציות (OWASP Top 10) Web

1. מה מנטרל SQL Injection בצורה הטובה ביותר?

- (א) להסתיר את הודעות השגיאה
- (ב) Prepared Statements / Parameterized Queries — הפרדת קוד מנתונים
- (ג) HTTPS

✓ תשובה: ב — שאילתות פרמטריות מפרידות בין הקוד לקלט, כך שקלט המשתמש לעולם אינו מתפרש כ-SQL. סינון בלבד שביר.

2. מה מונע Reflected XSS?

- (א) קידוד הפלט (Output Encoding) — הצגת `<script>` כטקסט ולא כקוד
- (ב) שימוש ב-POST במקום GET
- (ג) הסתרת שם השרת

✓ תשובה: א — Output Encoding הופך תווים מיוחדים (<, >, ") לישויות HTML, כך שהדפדפן מציג אותם כטקסט ולא מריץ אותם.

3. למה Command Injection נחשבת מהחולשות החמורות ביותר?

- (א) היא מאטה את האתר
- (ב) היא מאפשרת הרצת קוד כלשהו על השרת (RCE) — שליטה מלאה
- (ג) היא חושפת רק את שם השרת

✓ תשובה: ב — הרצת פקודות שרירותיות = RCE = הדרך הישירה ל-Shell ולשליטה מלאה במערכת.

4. מהו IDOR?

- (א) הצפנה חלשה
- (ב) גישה למשאב של משתמש אחר ע"י שינוי מזהה חשופ, בהיעדר בדיקת הרשאה בשרת
- (ג) הזרקת JavaScript

✓ תשובה: ב — Insecure Direct Object Reference: המזהה חשופ וניתן לשינוי, והשרת לא מוודא בעלות/הרשאה — אז משנים אותו וניגשים לנתוני אחרים.

מודול 10 — גלישת חוצץ (Buffer Overflow)

1. מדוע 16 בתים לא הספיקו, אבל 17 כן?

- (א) כי החוצץ בגודל 16, והבית ה-17 כבר "גלש" ודרס את המשתנה הסמוך
- (ב) כי 17 הוא מספר ראשוני
- (ג) כי strcpy עובד רק מעל 16 בתים

✓ תשובה: א — החוצץ מחזיק 16 בתים; כל בית מעבר לכך נכתב לזיכרון שאחריו — שם יושב authenticated. זו גלישת החוצץ.

2. מהי המטרה של שלב מציאת ה-Offset?

- (א) ליצור את ה-Shellcode
- (ב) לדעת בדיוק בכמה בתים נדרס ה-EIP, כדי למקם שם את הכתובת שנבחר
- (ג) לפתוח מאזין

✓ תשובה: ב — ה-Offset הוא המרחק המדויק עד ל-EIP. בלעדיו לא נדע היכן למקם את כתובת ה-JMP ESP. (בהדגמה המקומית — זה היה המרחק עד למשתנה authenticated).

מודול 11 — פוסט-אקספלויטציה והסלמת הרשאות (& Post-Exploitation Privilege Escalation)

1. למה קובץ SUID בבעלות root מסוכן?

- (א) הוא תופס הרבה מקום
- (ב) הוא רץ בהרשאות root גם כשמשמש מוגבל מפעיל אותו — ואם ניתן "לברוח" ממנו, מקבלים root
- (ג) אי אפשר למחוק אותו

✓ תשובה: ב — SUID גורם לבינארי לרוץ כבעליו (root). בינארי כזה שמאפשר הרצת פקודות (ראה GTFOBins) = הסלמה מיידית ל-root.

2. ב-Windows, איזו פקודה מציגה את ההרשאות המיוחדות של המשתמש (כמו SeImpersonatePrivilege)?

- (א) `whoami /priv`
- (ב) `ipconfig /all`
- (ג) `net user`

✓ תשובה: א — `whoami /priv` מציג את ה-Privileges של ה-Token הנוכחי; נוכחות SeImpersonatePrivilege פותחת מתקפות "Potato" ל-SYSTEM.

מודול 12 — Pivoting ותנועה רוחבית (Pivoting & Tunneling)

1. מה עושה `ssh -L 8080:10.10.10.30:80 user@pivot`?

- (א) מריץ nmap על ה-pivot
- (ב) פותח פורט מקומי 8080 שמנתב, דרך ה-pivot, אל 10.10.10.30:80 שברשת הפנימית
- (ג) מוחק את הלוגים ב-pivot

✓ תשובה: ב — Local Port Forwarding: localhost:8080 אצלך = 10.10.10.30:80 הפנימי, כשהתעבורה עוברת דרך חיבור ה-SSH ל-pivot.

2. למה חובה -sT (ולא -sS) כשמריצים nmap דרך proxychains?

- (א) -sT מהיר יותר
- (ב) פרוקסי SOCKS מעביר רק חיבורי TCP מלאים; סריקת SYN (-sS) חצי-פתוחה לא עוברת דרכו
- (ג) -sS דורש סיסמה

✓ תשובה: ב — SOCKS עובד ברמת החיבור (TCP Connect). -sS בונה חבילות גולמיות שלא עוברות בפרוקסי, ולכן משתמשים ב-sT (-Pn +).

מודול 13 — Active Directory (AD)

1. מה משיג התוקף מ-LLMNR/NBT-NS Poisoning עם Responder?

- (א) גישת Domain Admin מיידית
- (ב) את ה-NTLMv2 hash של משתמש שניסה לגשת לשם שגוי — לפיצוח offline
- (ג) את סיסמת ה-krbtgt

✓ תשובה: ב — Responder מתחזה לשרת ולוכד את ה-NTLMv2 hash שהקורבן שולח. אותו מפצחים (mode 5600) כדי לקבל אישורי משתמש ראשונים.

2. מדוע כל משתמש דומיין (גם מוגבל) יכול לבצע Kerberoasting?

- (א) כי כולם Domain Admins
- (ב) כי כל משתמש מאומת רשאי לבקש TGS של חשבונות שירות (SPN), וה-TGS מוצפן בסיסמת השירות — שנפצחת offline
- (ג) כי ה-DC פגיע לבאג

✓ תשובה: ב — זו "תכונה" של Kerberos: כל משתמש יכול לבקש service ticket. ה-TGS מוצפן ב-hash סיסמת השירות, וניתן לפצח אותו offline בלי לגעת שוב ב-DC.

3. מדוע NTLM hashes נחשבים חלשים יחסית לפיצוח?

- (א) הם ארוכים מדי
- (ב) הם MD4 של הסיסמה — ללא Salt וללא האטה — כך שאפשר לנסות מיליארדי ניחושים בשנייה

- (ג) אי אפשר לפצח אותם כלל

✓ תשובה: ב — NTLM = MD4 בלי Salt ובלי work-factor. אין הגנה מפני GPU, ואין הבדל בין שני משתמשים עם אותה סיסמה. סיסמה חלשה = פיצוח מידי.

מודול 14 — תקיפות אלחוטיות (Wireless Attacks)

1. מצאת רשת שעדיין משתמשת ב-WEP. מה המשמעות?

- (א) הרשת בטוחה מאוד
- (ב) ממצא קריטי — WEP שבור לחלוטין וניתן לפיצוח תוך דקות
- (ג) אי אפשר לתקוף אותה

✓ תשובה: ב — WEP שבור (חולשת ה-IV). נוכחותו היא ממצא קריטי מידי לדוח, ללא קשר לחוזק הסיסמה.

2. למה שולחים חבילות Deauthentication ללקוח מחובר?

- (א) כדי לפצח את הסיסמה ישירות
- (ב) כדי לנתק אותו — שיתחבר מחדש, וכך נלכוד את ה-4-Way Handshake
- (ג) כדי להאיץ את הרשת

✓ תשובה: ב — ה-Handshake נלכד רק ברגע ההתחברות. Deauth מכריח התחברות-מחדש כדי שלא נחכה. (הסיסמה מפוצחת אחר כך, offline).

3. מה הופך רשת WPA2 לעמידה בפני הפיצוח הזה?

- (א) הסתרת ה-SSID
- (ב) סיסמה ארוכה ואקראית שאינה נמצאת באף wordlist
- (ג) כיבוי ה-Handshake

✓ תשובה: ב — הפיצוח הוא מילוני/Brute Force על ה-Handshake. סיסמה חזקה ואקראית פשוט לא נמצאת ברשימות — ולכן הפיצוח נכשל. (אי אפשר "לכבות" Handshake).

4. איך מתקפת Evil Twin משיגה את הסיסמה גם כשה-WPA2 חזק מדי לפיצוח?

- (א) היא מפצחת את ה-Handshake מהר יותר

- (ב) היא מקימה AP מזויף עם אותו שם ומרמה את המשתמש להקליד את הסיסמה בעצמו (Captive Portal)
- (ג) היא משביתה את ה-WPA3

✓ תשובה: ב — Evil Twin עוקף את ההצפנה לגמרי: הוא לא מפצח כלום, אלא מטעה את המשתמש למסור את הסיסמה בדף מזויף. זו הנדסה חברתית (מודול 15).

מודול 15 — הנדסה חברתית ופשינג (Social Engineering & Phishing)

1. קיבלת מייל מ- `it-suport@company.com` (שים לב לאיות) עם "אמת את חשבונך תוך שעה או שייחסם". אילו שני סימני פשינג בולטים כאן?

- (א) דומיין/כתובת עם שגיאת כתיב + יצירת דחיפות ואיום
- (ב) המייל ארוך מדי
- (ג) אין בו לוגו

✓ תשובה: א — `it-suport` (חסר p) הוא דומיין דומה-אך-שגוי, ו"תוך שעה או שייחסם" הוא ניצול של דחיפות + פחד — צירוף קלאסי בפשינג.

2. למה MFA מקטין את הנזק מדרך נחיתה כזה?

- (א) הוא מונע מהדף להיטען
- (ב) גם אם הסיסמה נגנבת, לתוקף חסר הגורם השני (קוד/אישור) כדי להיכנס
- (ג) הוא מצפין את הסיסמה

✓ תשובה: ב — MFA דורש גורם שני מעבר לסיסמה. סיסמה גנובה לבדה כבר לא מספיקה. (כלים כמו evilginx מנסים לעקוף גם זאת ע"י גניבת ה-session — ולכן בדיקת ה-URL קריטית).

מודול 16 — כתיבת דוח ותיעוד (Reporting)

1. איזה חלק בממצא הופך אותו לניתן לשחזור ע"י צוות ה-IT?

- (א) כותרת הממצא
- (ב) ה-Proof of Concept (צעדים מדויקים + פקודות + צילומים)
- (ג) ההפניות ל-CVE

✓ תשובה: ב — ה-PoC עם הצעדים המדויקים מאפשר ל-IT לשחזר את החולשה בעצמם, לאמת אותה, ולוודא שהתיקון עבד.

2. איזה ממצא יקבל את ה-CVSS הגבוה ביותר, ככלל?

- (א) Command Injection המאפשר RCE לא-מאומת מרחוק על שרת ציבורי
- (ב) חולשת Low בדף פנימי
- (ג) כותרת Server חושפנית

✓ תשובה: א — RCE מרחוק, ללא אימות, עם השפעה מלאה על סודיות/שלמות/זמינות = הציון הגבוה ביותר (סביב 9.8-10.0, Critical). זה מה שמתקנים ראשון.